

OWASP Juice Shop - Vulnerability Identification Report

1. Injection

- SQL Injection (Login Admin, User Credentials, Database Schema)
- NoSQL Injection (NoSQL Manipulation, NoSQL Exfiltration, NoSQL DoS)
- SSTi (Server-Side Template Injection)

2. Cross-Site Scripting (XSS)

- DOM XSS
- Reflected XSS
- Stored XSS (API-only, HTTP Header, Video XSS)
- CSP Bypass
- Client-side & Server-side XSS Protection Bypass

3. Broken Authentication

- Weak Passwords (Admin login without change)
- Password Reset vulnerabilities (Bjoern, Jim, Bender, etc.)
- 2FA Weakness
- Brute Force Attacks

4. Broken Access Control

- Access Admin Section
- View/Manipulate other users' baskets
- CSRF Attack
- SSRF
- Forged Feedback/Reviews

5. Sensitive Data Exposure

- Exposed Credentials
- Access Logs Leakage
- Backup Files (Developer/Sales)
- API Key Leak
- Personal Data Theft (GDPR issues)

6. Security Misconfiguration

- Error Handling Issues
- Deprecated Interfaces
- Cross-Site Imaging

7. Improper Input Validation

- Empty/Invalid Registration
- File Upload Issues (Size/Type)
- Expired Coupons
- Null Byte Injection

8. Cryptographic Issues

- Weak Algorithms
- Forged Coupons
- JWT Forgery (Unsigned / Weak Signed)

9. XXE (XML External Entity)

- XXE Data Access
- XXE Denial of Service

10. Insecure Deserialization

- Memory Bomb
- Remote Code Execution (RCE DoS)

11. Vulnerable Components

- Outdated Libraries
- Typosquatting Attacks
- Supply Chain Issues

12. Broken Anti-Automation

- CAPTCHA Bypass
- Multiple Likes Abuse
- Mass Actions (Spam feedback)

13. Unvalidated Redirects

- Allowlist Bypass
- Outdated Redirect Links

14. Miscellaneous / OSINT / Web3

- Score Board discovery
- Security Policy & Privacy Policy
- Geo Stalking (Visual & Meta)
- NFT/Wallet attacks
- Hidden features (Easter Eggs)

15. TryHackMe (THM) Covered Vulnerabilities

- Security Misconfiguration: Improper error handling
- XSS: Reflected XSS
- Broken Access Control: View another user's basket
- Broken Access Control: Remove all 5-star feedback
- Sensitive Data Exposure: Login with MC SafeSearch credentials
- Sensitive Data Exposure: Access forgotten developer backup
- XSS: HTTP Header Stored XSS
- Improper Input Validation: Poison Null Byte attack